ONE-PAGE BRIEF

Post-quantum cryptography review: zebra @ 147a6a8bf7d3

Client: Zcash Foundation — public repository (passive review) · Source: github.com/ZcashFoundation/zebra, commit `147a6a8bf7d3` · Reviewed: 2026-10-29 23:49 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **2** High **13** Medium
5 Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-07371	**quinn-proto 0.11.16 is affected by RUSTSEC-2026-0340** What to do: Upgrade to a fixed version (0.11.18).
High QSI-2026-07372	**quinn-proto 0.11.16 is affected by RUSTSEC-2026-0341** What to do: Upgrade to a fixed version (0.11.17).
Medium QSI-2026-07350	**Quantum-vulnerable Ed25519 key (Ed25519) in SECURITY.md** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..
Medium QSI-2026-07367	**opentelemetry_sdk 0.31.0 is affected by GHSA-w9wp-h8wv-79jx (CVE-2026-48504)** What to do: Upgrade to a fixed version (0.32.1).

16 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the...
Medium transaction and message signing	Halo 2 (IPA), Ed25519, RedDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium role not determined	Halo 2 (IPA), Sinsemilla, RedDSA, X25519 ...	Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 10; unlikely to apply to this build: 1 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 9.

Analyst review: 0 confirmed, 0 not applicable, 1 dismissed as false positives. (QSI review, 2026-10-23)

Static review of source code and manifests; files analysed: 439. No requests were sent to the owner's systems.

Full report, content SHA-256: `91cfb3dd01b634fae7dd5a8e161479a5e242739f2957bd218e9a221f11e5df4c`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.